ATTACCO BRUTE FORCE E ANALISI DEI LOG TRAMITE WAZUH

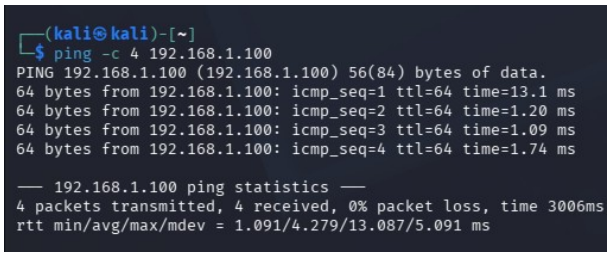
1. OBBIETTIVO

Simulare un attacco brute force per rilevare e analizzare l'attacco tramite SIEM (Wazuh)

2. AMBIENTE DI LAVORO

Per simulare un ambiente reale ho usato tre macchine virtuali su Virtual Box, che ho collegato in rete bridge:

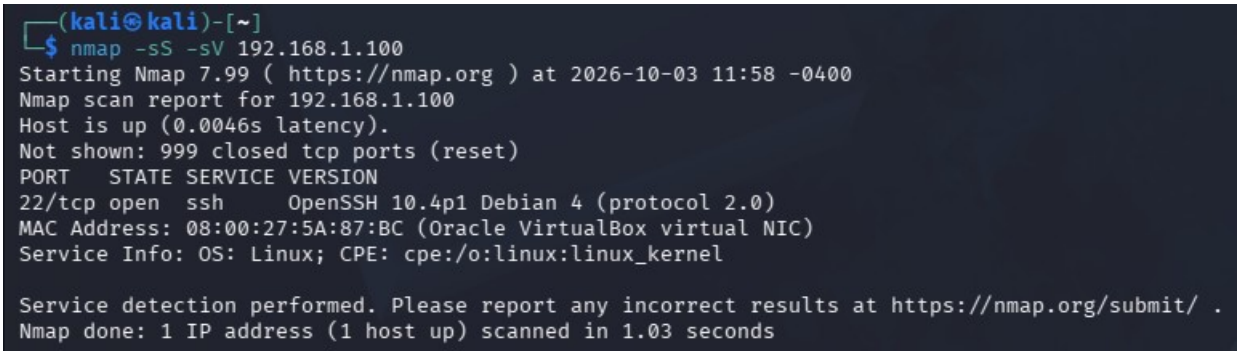
- KALI (192.168.1.100): Macchina target su cui è anche stato installato l'agente di Wazuh per poter accedere alla dashboard da browser per l'analisi di rete.
- KALI (192.168.1.50): Macchina attaccante
- WAZUH (192.168.1.166) : Server SIEM utilizzato per l'analisi dei log.



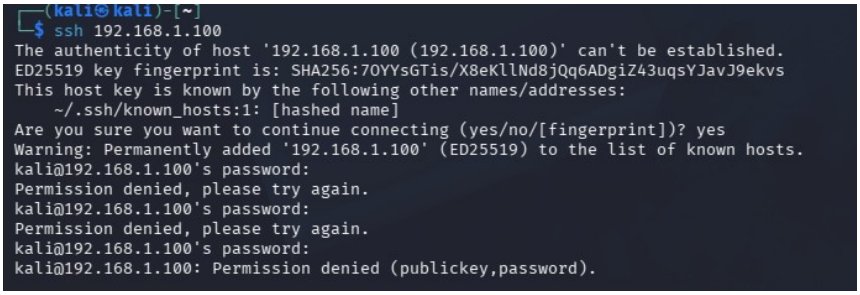
3. ATTACCO E ANALISI DEI LOG.

3.2 SIMULAZIONE D'ATTACCO

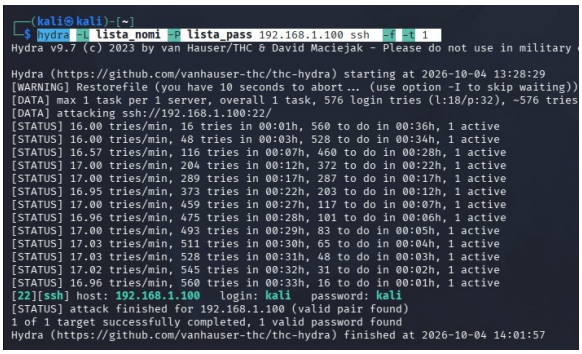
Per simulare un attacco vero è proprio ho iniziato con la fase di reconnaissance per scannerizzare le porte aperte e i relativi servizi in ascolto grazie al comando `nmap -sS -sV 192.168.1.166.` Ho usato -sS perché non completa l'handshake, quindi è meno rilevabile.



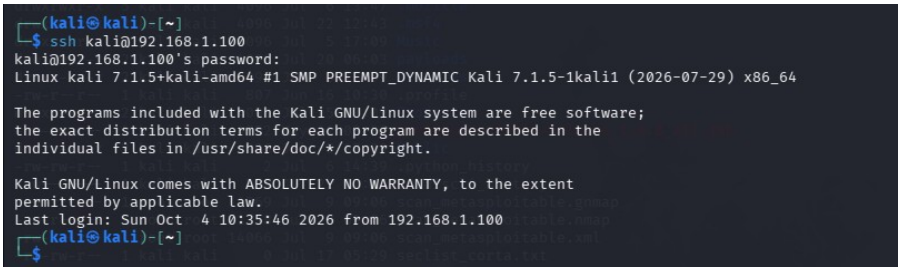
Questo dimostra che la porta 22 è un possibile vettore d'attacco. Sfruttando quest'informazione ho fatto un primo tentativo di accesso che ha confermato che il servizio SSH richiede l'autenticazione e ha anche permesso di visualizzare la fingerprint SHA256.



Per poter accedere ho tentato un attacco brute force sulla porta 22 utilizzando lo strumento Hydra. Ho preparato un dizionario limitato di password e username dove ho nascosto le credenziali corrette.
Ho dovuto ripetere l'attacco varie volte per trovare il rate-limitin del server SSH che è molto basso, infatti non si possono fare più tentativi di login in contemporanea.
Alla fine il comando giusto è `hydra -L lista_nomi -P lista_pass 192.168.1.100 ssh  -f -t 1.`



L'attacco ha avuto successo e sono stati individuati username e password kali:kali.

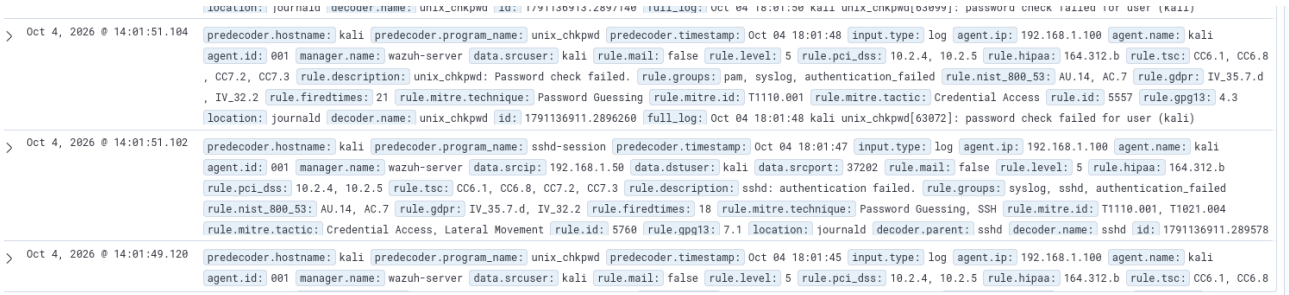


Come mostrato nell'immagine soprastante con le credenziali si accede al servizo ottenendo la shell.

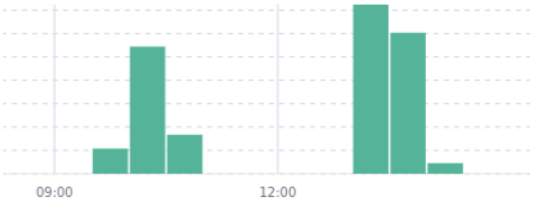
2.2 FASE DI ANALISI DEI LOG

La macchina target è collegata a Wazuh, quindi ho fatto l'analisi tramite la dashboard del SIEM accedendo tramite browser.

All'interno della pagina discovery si possono vedere i vari log provenienti dalla macchina attaccata, tra i quali vi sono vari accessi falliti tipico di un Brute force.



Osservando l’intervallo temporale delle ultime 24 ore si notano due picchi di interazioni: 9:30-10:30 e 13:00-14:00 del 4/10/2026.



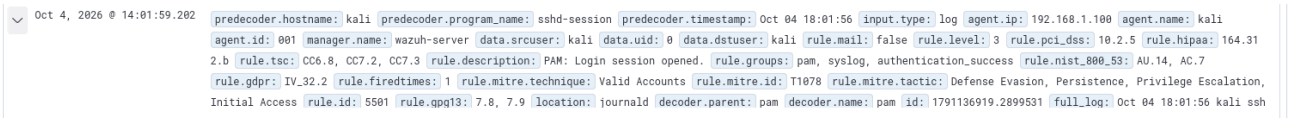
In entrambi gli intervalli si osservano tentativo di accesso falliti che dimostrano che l’attaccante ha agito in due momenti diversi.

Osservando l’attacco più da vicino e analizzando un log delle 10:28:31.572 il SIEM permette di ottenere varie informazioni:

- **192.168.1.50** → IP dell’attaccante.
- **T1110.001** – Brute Force: Password Guessing - Tecnica specifica riferita al Framework MITRE ATT&CK → Vari tentativi di accesso con un dizionario di credenziali per individuare la coppia corretta.
- **T1021.004** – Remote Services: SSH Tecnica specifica riferita al Framework MITRE ATT&CK→ Sottotecnica del Lateral Movemment per avviare una sessione SSH e controllare sistemi remoti.
- **Credential Access** → Tentativi ripetuti di indovinare la password (*Password Guessing*) per violare l'account SSH.
- **Lateral Movement** -Tattica specifica riferita al Framework MITRE ATT&CK→ Sfruttamento della sessione SSH stabilita per mantenere l'accesso remoto e muoversi sul sistema.
- **Rule.level 5**→ Indica, secondo una scala di severità che va da 0-15, un evento sospetto.
- **NIST SP 800-53 (AU.14, AC.7, AU.6)** → Riferimenti ai controlli di sicurezza standard per la gestione dei tentativi di accesso falliti consecutivi e il monitoraggio dei log di audit.
- **PCI DSS e TSC (10.2.4, CC7.2)** → Standard di conformità che tracciano l'autenticazione fallita e la capacità di rilevare anomalie e minacce in tempo reale.

- **TSC (CC6.1 & CC6.8)** → Violazione dei criteri di sicurezza sui controlli d'accesso logico, mirati a prevenire intrusioni non autorizzate mediante credenziali compromesse.
- **TSC (CC7.2 & CC7.3)** → Violazione dei criteri di controllo relativi al rilevamento tempestivo delle anomalie e al monitoraggio continuo delle minacce di sicurezza.
- **HIPAA (164.312.b)** → Violazione dei controlli di audit e tracciamento delle attività non autorizzate sui sistemi che gestiscono dati sensibili.
- **GDPR (Art. 32.2, 35.7.d)** → Violazione dei requisiti di sicurezza e protezione dei dati personali contro accessi non autorizzati e tentativi di intrusione

Continuando con l'indagine Wazuh ha registrato un'autenticazione riuscita da parte dell'IP dell'attore delle minaccia alle ore 14:01:59.202:



- **192.168.1.50** → È lo stesso IP dell'attore del Brute force.
- **Rule.level 3** → Severità bassa poiché il sistema non avendo un contesto storico non è capace di identificare autenticazione legittima da quella illeggittima senza intervento umano.
- **T1078 – Valid Accounts** → Tecnica specifica riferita al Framework MITRE ATT&CK: utilizzo di credenziali veramente esistenti per accedere al sistema.
- **Initial Access -** Tattica specifica riferita al Framework MITRE ATT&CK → Rappresenta l'accesso iniziale ottenuto sfruttando le credenziali valide appena indovinate.
- **Persistence** - Tattica specifica riferita al Framework MITRE ATT&CK → Indica la capacità dell'attaccante di mantenere l'accesso acquisito nel tempo.
- **Privilege Escalation** - Tattica specifica riferita al Framework MITRE ATT&CK → Copre i tentativi di ottenere privilegi superiori (es. privilegi di root) partendo dall'account compromesso.
- **Defense Evasion** - Tattica specifica riferita al Framework MITRE ATT&CK → Riguarda le tecniche messe in atto per eludere i controlli di sicurezza ed evitare di essere rilevati.
- **NIST 800-53 (AU.14, AC.7)** → Riguarda la generazione di log di audit, il monitoraggio delle sessioni e la gestione dei tentativi di accesso non autorizzati.
- **PCI DSS (10.2.5)** → Impone la tracciabilità e il monitoraggio di tutti gli utilizzi di identificativi utente privilegiati o validi.
- **TSC (CC6.8, CC7.2, CC7.3)** → Controlli relativi alla protezione dei sistemi e degli endpoint da accessi non autorizzati, al monitoraggio delle anomalie e alla gestione degli incidenti.
- **HIPAA (164.312.b)** → Implementazione di meccanismi di controllo e registrazione strutturata delle attività sui sistemi informativi.

- **GDPR (IV_32.2)** → Adozione di misure tecniche e organizzative adeguate per garantire la sicurezza del trattamento e la protezione dei dati.

4. CONCLUSIONE

Il presente progetto ha permesso di portare a termine un'analisi completa, integrando le prospettive di Blue Team e Red Team.

PROSPETTIVA RED TEAM→ È stato eseguito un attacco completo che ha consentito l'accesso al server SSH. Prima è stato svolta la fase di *ricognizione* che ha permesso di confermare l'apertura della porta 22 poi seguita da un *Credential Access* tramite Brute force che ha individuato le credenziali di accesso con cui si è ottenuto un primo accesso. L'operazione è stata però rallentata dalla presenza di un rate-limiting, che non ha permesso di eseguire più tentativi in parallelo.

PROSPETTIVA BLUE TEAM→ Grazie alla piattaforma di SIEM Wazuh si è svolta anche un'analisi dei log per individuare tentativi falliti di login, che il SIEM ha riconosciuto come possibili attacchi *password guessing* assegnando un punteggio di severità 7, che corrisponde ad una minaccia sospetta. Inoltre ha anche mappato gli standard normativi e di compliance internazionale e le possibili violazioni dei requisiti di sicurezza. Infine è stato possibile anche notare l'autenticazione eseguita con successo da parte dell'IP (192.168.1.50) sospettato di aver tentato il Brute force, tuttavia il sistema assegna un punteggio basso di severità (3), poiché non è in grado di esaminare il contesto dell'evento sottolineando l'importanza dell'indagine umana.